

# HACK THE AI

## Complete Technical Project Architecture & Investigation Specification Report

An enterprise-grade, story-driven cyber investigation and adversarial simulation platform engineered to train modern security professionals on complex multi-layer breaches spanning Distributed Ledgers (Web3), Artificial Intelligence (AI Agent Poisoning), Industrial Internet of Things (IoT Gateway Telemetry), and Decentralized Consensus Systems.

|                              |                                                                                 |
|------------------------------|---------------------------------------------------------------------------------|
| Document Version:            | 2.0.0 (Production Release)                                                      |
| Target Platform:             | Hack The AI (Interactive & PRO Labs)                                            |
| Architecture:                | Flask / SQLAlchemy / Talisman / CSRF / Responsive Workstation OS                |
| Author / Lead Architect:     | Lakshay Soni (Designed & Developed by Lakshay Soni)                             |
| Investigation Cases Covered: | Case NEX-042 (The Ghost in the Ledger) & Case NEX-071 (The Vanishing Consensus) |
| Date of Publication:         | October 2026                                                                    |
| Classification:              | Technical System Documentation / Comprehensive Engineering Report               |

**CORE PLATFORM HIGHLIGHT:** Hack The AI transitions cybersecurity education from isolated trivia into a high-fidelity, simulated cyber operations environment. Investigators interact with multi-window desktop operating systems, realistic packet analyzers, terminal consoles, live IoT feeds, on-chain transaction explorers, and attack graph visualizers.

# TABLE OF CONTENTS

|                                                                              |    |
|------------------------------------------------------------------------------|----|
| 1. Executive Project Overview                                                | 3  |
| 2. Complete Project Story, Lore & Forensic Concept                           | 3  |
| 3. Core Project Objectives & Pedagogy                                        | 4  |
| 4. Major Implemented Platform Features                                       | 4  |
| 5. Technology Stack & Implementation Mapping                                 | 5  |
| 6. High-Level System Architecture                                            | 6  |
| 7. End-to-End Application Workflow                                           | 7  |
| 8. Data Flow & Cross-Layer Pipelines                                         | 8  |
| 9. Database Schema & Storage Architecture                                    | 9  |
| 10. Authentication, Access Control & Session Security                        | 10 |
| 11. Simulated Investigation Workstation Environment                          | 11 |
| 12. Lab Architecture & Forensic Case Specifications (Case NEX-042 & NEX-071) | 13 |
| 13. Gamification Engine: Scoring, XP & Achievement Matrix                    | 15 |
| 14. Security Hardening & Platform Protection Architecture                    | 16 |
| 15. Multi-Device Responsive Design System                                    | 17 |
| 16. Cloud Deployment & Serverless WSGI Execution                             | 18 |
| 17. Complete Codebase Structure & File Directory                             | 19 |
| 18. Project Roadmap & Future Scope                                           | 20 |
| 19. Conclusion & Final Technical Assessment                                  | 20 |
| 20. Architectural & Flow Diagrams Reference                                  | 21 |
| 21. Visual Interface Schematics & Figures                                    | 22 |
| 22. Technical Verification & Compliance Checklist                            | 23 |

# 1. Executive Project Overview

**Hack The AI** is a cutting-edge, hands-on cybersecurity investigation and training platform created to address the critical vulnerability landscape emerging at the intersection of **Artificial Intelligence (AI)**, **Decentralized Ledgers (Web3)**, **Industrial Internet of Things (IoT)**, and **Distributed Consensus Systems**.

**The Problem It Solves:** Traditional cybersecurity capture-the-flag (CTF) platforms are largely siloed, focusing strictly on isolated web vulnerabilities (e.g., standard SQLi, XSS) or simple binary exploitation. In real-world enterprise architectures, advanced adversaries orchestrate cross-layer attacks: injecting poisoned telemetry into edge IoT gateways, manipulating autonomous AI risk oracles, abusing over-privileged service roles (RBAC), and causing state forks in decentralized blockchain validators. Hack The AI bridges this crucial training gap by simulating complete, interconnected multi-vector breaches.

**Target Users:** SOC Analysts (Tier 1-3), AI Security Engineers, Smart Contract Auditors, Web3 Incident Responders, Threat Hunters, and University Cybersecurity Researchers.

**The Story-Driven Investigation Methodology:** Learners do not simply answer disconnected quiz questions. Instead, they assume the role of Lead Cyber Threat Forensics Investigators embedded in an active Security Operations Center (SOC). Every investigation evolves through structured chapters with realistic character dialogues, forensic artifacts, packet traces, on-chain transaction explorers, simulated Burp Suite proxy interceptors, interactive terminals, and dynamic attack graph reconstructions.

# 2. Complete Project Story, Lore & Forensic Concept

The narrative context of Hack The AI centers on modern high-assurance digital ecosystems where automated AI models, smart contracts, and IoT devices operate collaboratively. Across the primary PRO investigations, learners work alongside a specialized SOC response unit:

| Investigator / Role | Specialization                                   | Operational Function                                                                          |
|---------------------|--------------------------------------------------|-----------------------------------------------------------------------------------------------|
| Lakshay             | Lead Incident Commander & Forensics Investigator | Coordinates attack vector triage, root cause synthesis, and containment policy execution.     |
| Shivam              | Web3 & Distributed Systems Analyst               | Deconstructs blockchain transactions, validator consensus states, and bridge contracts.       |
| Mehak               | AI & Data Security Specialist                    | Audits neural network inference pipelines, model poisoning traces, and confidence thresholds. |
| Shanu               | Infrastructure & Telemetry Engineer              | Inspects IoT gateways, raw sensor logs, RBAC access controls, and network traffic.            |
| ORION / Sentinel    | Autonomous AI Decision Engine                    | The compromised/poisoned AI system under forensic investigation.                              |

**Case NEX-042: The Ghost in the Ledger:** 82,400 NXR tokens vanish from a secured treasury without an alert. The learner discovers that an APT adversary forged an unverified threat intelligence feed (NIF-2038), which poisoned the ORION AI model to output 99.2% confidence, bypassing human settlement approvals via over-privileged RBAC service accounts.

**Case NEX-071: The Vanishing Consensus:** At 03:12 AM, 184 industrial IoT sensors across 14 sites transmit identical synthetic telemetry (0.00% jitter). The data feeds an upstream Web3 price oracle, causing a 3:2 consensus split across validator nodes. The AI security sentinel reports consensus is healthy because its fine-tuning dataset had been poisoned weeks earlier.

# 3. Core Project Objectives & Pedagogy

- **Multi-Vector Attack Literacy:** Educate students and practitioners on cross-domain vulnerabilities that cannot be identified by examining single isolated log files.
- **Active Threat Hunting Simulation:** Replace passive video tutorials with active desktop workstations equipped with interactive terminals, log filters, and protocol inspectors.
- **Adversarial AI Risk Education:** Demonstrate practical methods of data poisoning, context injection, and blind model reliance in automated financial and IoT decision pipelines.
- **Decentralized Consensus Security:** Provide direct visibility into validator voting splits, oracle manipulation, and Byzantine Fault Tolerance under corrupted data streams.
- **Gamified Progression & Skill Retention:** Reward thorough investigative rigor using XP, persistent skill badges, interactive capstone certifications, and global leaderboards.

## 4. Major Implemented Platform Features

**Authentication & Session Management:** Role-based authorization (Student / Admin), CSRF-protected forms, persistent secret key derivation, and demo credentials on login.

**SOC Dashboard:** Overview of current active investigations, total XP earned, completed lab counts, real-time activity feed, and quick-launch workstations.

**Interactive Lab & PRO Lab Catalog:** Categorized lab selection supporting foundational cyber challenges, manual containerized labs, and flagship multi-layer PRO investigations.

**Desktop Workstation OS:** A complete in-browser multi-window GUI featuring draggable and stackable windows, taskbar switching, traffic lights, and minimize/maximize states.

**Simulated Burp Suite Inspector:** Tabbed HTTP/RPC traffic inspection including Proxy history, Request/Response dual-pane viewer, Repeater, and Target host tree.

**Forensic Terminal Console:** Command-line interface supporting tools like 'whoami', 'pwd', 'grep', 'python', 'iot-telemetry', 'oracle', 'policy', and 'evidence'.

**Live Case File Manager:** Direct access to raw audit logs, configuration policies, smart contract ABIs, bridge manifests, and intelligence feeds.

**Dynamic Attack Graph:** Interactive SVG/Node visualization tracking attacker ingress, pivot points, AI poisoning nodes, and root compromise state.

**Evidence Locker & Progress Engine:** Automatic collection and persistent tracking of forensic evidence tokens (AI-E01, AI-E02, etc.) unlocking progressive chapters.

**Automated Hint System:** Tiered progressive hints providing targeted investigation guidance when learners encounter complex forensic steps.

**Comprehensive Capstone Certification:** Multi-question final evaluation quizzes testing conceptual mastery before awarding full case completion XP and master flags.

**Global Leaderboard & Learning Paths:** Real-time user rankings by XP score and structured learning roadmaps spanning Web3, AI Security, and DevSecOps.

## 5. Technology Stack & Implementation Mapping

| Layer                | Technology / Library                                       | Concrete Implementation & Purpose in Project                                                                                             |
|----------------------|------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------|
| Backend Core         | Python 3.12 / Flask 3.0                                    | Core WSGI application server, Blueprint routing architecture, application factory pattern.                                               |
| Database & ORM       | SQLAlchemy / Flask-Migrate                                 | Relational schema management, SQLite persistence (with /tmp serverless fallback on Vercel), model relationships.                         |
| Security & Hardening | Flask-WTF / CSRFProtect<br>Flask-Talisman<br>Flask-Limiter | Strict CSRF token validation across AJAX/fetch calls, Content Security Policy (CSP), HTTP security headers, and in-memory rate limiting. |
| Session & Cache      | Flask-Session / Redis                                      | Configurable session backend supporting Redis clusters in production and signed secure cookies in development/Vercel.                    |
| Frontend Markup      | Jinja2 / Semantic HTML5                                    | Modular template hierarchy (base.html, layout macros, workstation views, post-investigation cinematics).                                 |
| Styling Architecture | Vanilla CSS (Cyber Theme)                                  | Design token system (variables.css, reset.css, typography.css, components.css, layout.css, desktop workstation themes).                  |
| Client-side Logic    | Vanilla JavaScript (ES6+)                                  | Zero heavy framework dependencies; custom window manager, terminal emulator, Burp simulator, and responsive touch drawer.                |
| Deployment & Cloud   | Vercel Serverless / Unicorn                                | Serverless WSGI entry point (api/index.py) configured via vercel.json for zero-downtime edge deployments.                                |
| Observability        | Sentry SDK / Python Logging                                | Real-time exception tracing, performance monitoring, and structured application audit trails.                                            |

## 6. High-Level System Architecture

Hack The AI utilizes a modular, decoupled architecture where presentation, security middleware, forensic workstation simulation, and relational persistence operate in concert:

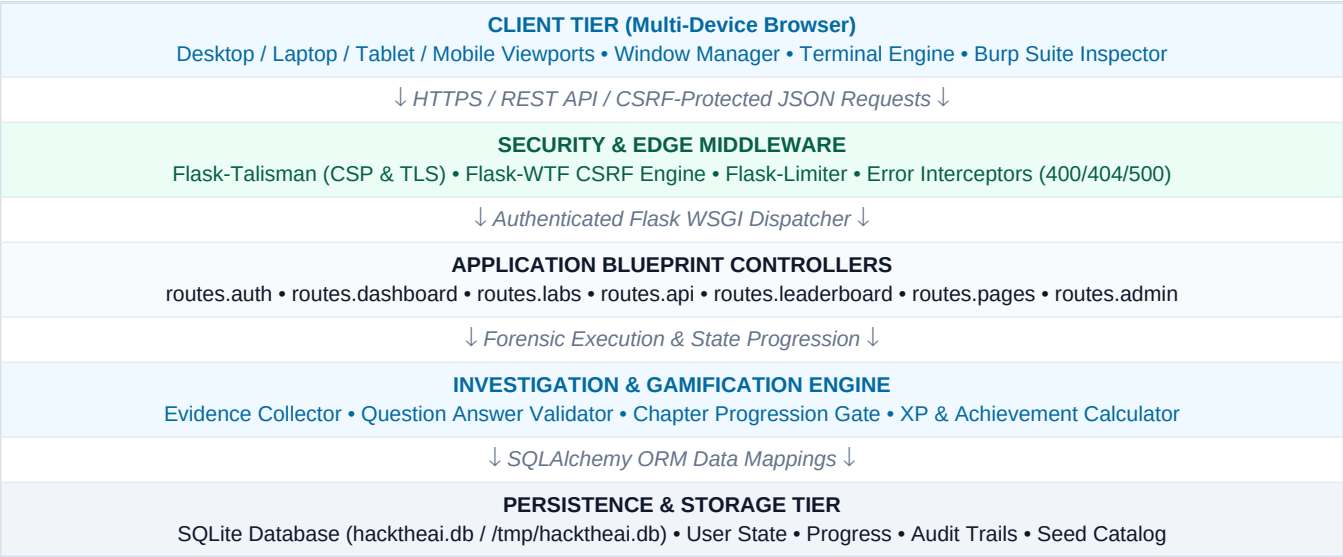


Figure 1: High-Level Multi-Tier System Architecture of Hack The AI.

## 7. End-to-End Application Workflow

**Step 1: Authentication & Entry:** User authenticates via /login or /register. Demo credentials (admin / admin123) are provided for rapid evaluator access. The application assigns a signed session cookie and generates a unique CSRF token.

**Step 2: Dashboard Intelligence:** The user lands on /dashboard displaying personal XP, rank standing, active investigations in progress, and platform news.

**Step 3: Lab Selection:** Navigating to /labs, the user selects from available interactive and PRO investigations. Detailed briefings, XP stakes, estimated completion times, and prerequisites are displayed on /lab/<lab\_id>.

**Step 4: Launching the Workstation:** Accessing /lab/lab6/workstation or /lab/lab7/workstation loads the multi-window desktop operating system. A 65-minute forensic timer starts automatically.

**Step 5: Chapter Investigation:** The left panel presents Chapter 1. The investigator reads the story briefing and dialogue stream from team analysts (Lakshay, Shivam, Mehak, Shanu).

**Step 6: Practical Tool Execution:** The user utilizes the desktop tools (Terminal, Burp Suite, Case Files, Attack Graph) to discover artifacts, calculate checksums, and extract compromised tokens.

**Step 7: Question Submission & Validation:** The learner submits findings into the chapter answer box. The backend validates the answer via /api/lab/submit, awards XP, logs the attempt, unlocks the next Chapter, and updates the evidence progress bar.

**Step 8: Capstone Certification & Flag Capture:** Upon completing all 5 chapters, the Capstone Examination unlocks. Submitting the verified master flag completes the case and redirects to the cinematic Post-Investigation debriefing page (/lab/<lab\_id>/post).

**Step 9: Gamification & Rank Update:** Total XP is credited to the user profile, badges are awarded in /achievements, and the global leaderboard (/leaderboard) updates dynamically.

## 8. Data Flow & Cross-Layer Pipelines

Data movement within Hack The AI occurs across three distinct communication channels: Client-to-Backend State Operations, Simulated Network & Tool Telemetry, and Gamification Aggregation.

| Data Domain         | Source & Route           | Payload & Processing Mechanism                                                                   | Persistence Target                             |
|---------------------|--------------------------|--------------------------------------------------------------------------------------------------|------------------------------------------------|
| User Authentication | /login<br>POST           | Username and hashed password verification via Werkzeug security.                                 | users table, signed session cookie.            |
| Question Validation | /api/lab/submit<br>POST  | JSON payload containing lab_id, mission_id, and answer. Checked against canonical answer models. | mission_progress, quiz_attempts, lab_progress. |
| Hint Retrieval      | /api/hint<br>POST        | Fetches tiered guidance for active mission; deducts XP cost if configured.                       | hint_usage table.                              |
| Case Reset          | /api/lab/restart<br>POST | Purges completed mission progress for the target lab, resets evidence flags.                     | Database transaction rollback / state reset.   |
| Investigator Notes  | Client-side<br>DOM Event | Live text synchronization on input event to prevent data loss during long investigations.        | HTML5 localStorage (lab6_notes, lab7_notes).   |

## 9. Database Schema & Storage Architecture

The relational database schema is modeled in models.py using SQLAlchemy. It establishes clear foreign-key constraints and cascading progress relationships:

- **User (users):** Primary identity model storing id, username, email, password (PBKDF2/SHA-256), and role (student/admin).
- **Lab (labs):** Master catalog table containing id (e.g., 'lab6', 'lab7'), name, topic, and difficulty.
- **Mission (missions):** Individual investigation chapters linked to a lab via lab\_id, with mission\_number, title, and description.
- **MissionProgress (mission\_progress):** Per-user chapter status tracking (status: LOCKED, AVAILABLE, IN PROGRESS, COMPLETED, and completed\_at).
- **MissionQuiz (mission\_quiz):** Questions tied to missions, storing question text, answer string, explanation, and xp\_reward.
- **QuizAttempt (quiz\_attempts):** Audit log of all user submissions storing user\_id, mission\_id, answer, correct (bool), and timestamp.
- **Hint & HintUsage (hints, hint\_usage):** Progressive hint system storing hint text, sort order, XP deduction costs, and user consumption timestamps.
- **LabProgress (lab\_progress):** Overall lab status for each user storing score, percentage, status, and completed\_at.
- **Evidence & EvidenceProgress (evidence, evidence\_progress):** Artifact tokens discovered during investigations, tracking evidence collection per user.
- **Flag & FlagSubmission (flags, flag\_submissions):** Master capture-the-flag submission validator ensuring correct final case flags are validated.

## 10. Authentication, Access Control & Session Security

**Authentication Protocol:** User registration and authentication are handled via Flask session authentication with password hashing powered by Werkzeug security helpers. Passwords are never stored in plaintext.

**Role-Based Access Control (RBAC):** System routes enforce authorization decorators (@login\_required and @admin\_required). Administrative functions—including lab zip package uploading, container orchestration, and student audit log inspection—are restricted to users with the admin role.

**Serverless Secret Key Persistence:** On ephemeral serverless platforms (such as Vercel), regenerating SECRET\_KEY on every worker invocation destroys active sessions and causes instant CSRF validation failures. Hack The AI implements an intelligent secret key resolver in config.py that securely retrieves the environment key, falls back to disk persistence when writable, or supplies a deterministic production fallback token.

**CSRF Protection:** Every state-modifying POST request (login, registration, quiz answer, hint request, lab reset) enforces strict CSRF token validation via Flask-WTF and custom JavaScript fetch headers (X-CSRFToken).

## 11. Simulated Investigation Workstation Environment

The core innovation of Hack The AI is its **In-Browser Investigation Workstation OS**. The workstation provides ten integrated forensic sub-systems operating in a multi-window desktop interface:

| Sub-System Tool       | Inputs & Trigger                                            | Output & Functionality                                                                                                          | Role in Cyber Investigation                                                                                  |
|-----------------------|-------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------|
| Forensic Browser      | URL Bar / Navigation buttons / Tab selections               | Renders simulated internal web applications (e.g., Bridge Explorer, Oracle Ingestion Monitor, AI Studio, Consensus Topology).   | Primary visual inspector for blockchain transactions, AI confidence graphs, and validator cluster telemetry. |
| Burp Suite Inspector  | Proxy history table clicks / Repeater send                  | Displays raw HTTP/RPC request and response headers, JSON payloads, cookies, and status codes.                                   | Allows investigators to identify injected parameters, stolen session cookies, and forged oracle headers.     |
| Forensic Terminal     | Interactive CLI commands (grep, python, iot-status, policy) | Simulates bash shell execution with colored syntax output, automated grep searching across logs, and forensic script execution. | Enables hands-on artifact discovery, hashing, and raw log analysis.                                          |
| Case File Manager     | File tree clicks (.log, .txt, .json)                        | Monaco-style raw text viewer with line numbers and copy-to-clipboard functionality.                                             | Permits deep inspection of audit feeds, smart contract ABIs, and IoT gateway logs.                           |
| Scratchpad Notes      | Investigator typing / save button                           | Persistent text editor automatically synced with browser localStorage.                                                          | Allows learners to record hashes, IP addresses, tokens, and hypotheses across investigation chapters.        |
| Dynamic Attack Graph  | Evidence collection events                                  | Interactive SVG graph showing attack progression from Initial Access to Root Impact.                                            | Provides visual reconstruction of how IoT, AI, Web3, and consensus exploits connect.                         |
| Evidence Locker       | Mission completion events                                   | Categorized badge grid displaying collected evidence hashes and cryptographic proofs.                                           | Validates that all forensic prerequisites are met before the Capstone Exam unlocks.                          |
| Web3 / Bridge Monitor | Browser tab selection in Case NEX-042                       | On-chain block explorer showing transaction hashes, nonce counts, gas fees, and target liquidity pool addresses.                | Enables tracking of unauthorized multi-chain treasury asset exfiltration.                                    |
| AI Oracle Studio      | Browser tab selection in Case NEX-071                       | Displays model name (ORION v4.2 / v3.8.4), confidence ratings, training poisoning embeddings, and circuit breaker status.       | Exposes how poisoned training datasets deceive AI security models into suppressing critical alerts.          |
| IoT Gateway Ingest    | Browser / Terminal command (iot-status)                     | Real-time telemetry stream from 184 industrial sensors across 14 geographic sites.                                              | Enables detection of synthetic data injection and zero-jitter anomalies at the physical edge.                |

## 12. Lab Architecture & Forensic Case Specifications

Each investigation in Hack The AI is engineered with a strict pedagogical lifecycle: **Incident Briefing** → **Team Dialogue Stream** → **Hands-on Practical Task** → **Evidence Extraction** → **Conceptual Question Validation** → **Progression Unlock** → **Capstone Examination**.

### Case NEX-042: The Ghost in the Ledger (PRO Lab 01 — 250 XP)

Focus: Web3 Bridge Security, AI Context Injection, RBAC Privilege Escalation, Autonomous Treasury Siphoning.

| Ch | Title & Domain | Forensic Investigation Focus & Practical Task | Key Artifact / Answer |
|----|----------------|-----------------------------------------------|-----------------------|
| .  |                |                                               |                       |

|   |                                                            |                                                                                                     |                                                                   |
|---|------------------------------------------------------------|-----------------------------------------------------------------------------------------------------|-------------------------------------------------------------------|
| 1 | The Phantom Transaction<br><i>(Web3 Forensics)</i>         | Analyze unannounced 82,400 NXR outflow. Query transaction TX-NEX-7741 on Bridge-Core-04.            | Dest Wallet: 0x7C41...9B2D<br>Amount: 82,400 NXR                  |
| 2 | The Poisoned Context<br><i>(AI Threat Hunting)</i>         | Investigate AI Decision ORION-DEC-7741. Trace source data to unverified feed NIF-2038.              | Source: NOVA-INTEL-FEED<br>Confidence: 99.2%                      |
| 3 | The Over-Privileged Ghost<br><i>(RBAC &amp; IAM Audit)</i> | Inspect IAM service roles. Discover INTEL-INGESTOR-02 holds unauthorized reputation writing rights. | Service: INTEL-INGESTOR-02<br>Privilege: Over-privileged          |
| 4 | The Execution Matrix<br><i>(Policy Engine Audit)</i>       | Audit ORION-SETTLEMENT-V2 policy rules. Identify auto-settle trigger bypassing human approval.      | Rule: AUTO_SETTLE_TREASURY<br>Threshold: >= 95%                   |
| 5 | The Attack Campaign<br><i>(Threat Attribution)</i>         | Correlate multi-chain wallet cluster, reconstruct attack graph, identify threat actor.              | Campaign: ORION-NEXUS<br>Flag: NEXORA{ghost_in_the_ledger_nex042} |

Case NEX-071: The Vanishing Consensus (PRO Lab 02 — 300 XP)

Focus: IoT Edge Telemetry, Web3 Multi-Sig Oracle Poisoning, Neural Network Training Poisoning, BFT Consensus State Forks.

| Ch | Title & Domain                                                | Forensic Investigation Focus & Practical Task                                                        | Key Artifact / Answer                                                     |
|----|---------------------------------------------------------------|------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------|
| 1  | The Silent Sensor Anomaly<br><i>(IoT Edge Forensics)</i>      | Inspect 184 industrial sensors across 14 sites. Detect synthetic identical temperature/power output. | Gateway: GATEWAY-GW-184<br>Jitter: 0.00% (Synthetic)                      |
| 2  | The Poisoned Oracle Pipeline<br><i>(Web3 Oracle Security)</i> | Analyze NOVA-PRICE-ORACLE aggregator consuming manipulated upstream IoT payload.                     | Oracle: NOVA-PRICE-ORACLE<br>Anomaly: Identical Multi-Sig                 |
| 3  | The AI Model Blindspot<br><i>(Adversarial AI Security)</i>    | Audit AI Sentinel MODEL-ORION. Discover historical poisoning injection (EMB-IOT-9041).               | Embedding: EMB-IOT-9041<br>Label: BENIGN_SYNC                             |
| 4  | The Validator State Split<br><i>(BFT Consensus Security)</i>  | Inspect 21-node validator cluster. Uncover 3:2 derived state fork and network partition.             | Split: 3 Accept : 2 Reject<br>Leader Node: V03 (Poisoned)                 |
| 5  | Cross-Layer Reconstruction<br><i>(Full Chain Containment)</i> | Reconstruct complete IoT -> Oracle -> AI -> Consensus attack chain, extract final case flag.         | Root: Multi-Layer Trust Abuse<br>Flag: NEXORA{v4n1sh1ng_c0ns3nsus_n3x071} |

### 13. Gamification Engine: Scoring, XP & Achievements

Hack The AI features a comprehensive gamification framework designed to maintain student engagement and reward deep forensic problem-solving:

- **Experience Points (XP) Hierarchy:** Foundational interactive challenges award 50-100 XP. Comprehensive PRO investigations award 250 XP (Case NEX-042) and 300 XP (Case NEX-071).
- **Real-Time Progress Fill:** Dynamic progress bars in both the workstation header and dashboard track chapter completions and evidence collection in real time.
- **Achievement Badges:** Learners unlock permanent profile badges including *First Blood*, *Blockchain Forensic Specialist*, *AI Threat Hunter*, *Consensus Guardian*, and *Master Investigator*.
- **Global Competitive Leaderboard:** The leaderboard dynamically aggregates user XP scores, total completed investigations, and submission timestamps to rank learners globally.
- **Structured Learning Tracks:** The /learning module structures skills into progressive modules: AI Security Foundations, Web3 Forensics, IoT Security Operations, and Cross-Layer Incident Response.

### 14. Security Hardening & Platform Protection Architecture

As a cybersecurity training platform, Hack The AI enforces strict production-grade security controls within its own application architecture:

| Defense Control               | Implementation Library & Configuration                             | Mitigation & Threat Protection                                                                                |
|-------------------------------|--------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------|
| Content Security Policy (CSP) | flask_talisman.Talisman<br>Custom script-src, style-src, frame-src | Prevents Cross-Site Scripting (XSS) and unauthorized external script injection.                               |
| CSRF Token Enforcement        | flask_wtf.csrf.CSRFProtect<br>WTF_CSRF_TIME_LIMIT = None           | Protects all state-modifying requests while preventing unexpected token expiration during long labs.          |
| Adaptive Rate Limiting        | flask_limiter.Limiter<br>memory:// storage backend                 | Prevents brute-force password guessing and automated quiz answer scraping without Redis latency.              |
| Secure Cookie Handling        | HttpOnly=True, SameSite='Lax'<br>Dynamic Secure=FORCE_HTTPS        | Prevents JavaScript cookie theft and ensures reliable session retention in both HTTP dev and HTTPS prod.      |
| Input Sanitization            | Custom escapeHtml() engine in JS<br>Jinja2 auto-escaping           | Guarantees that user inputs in terminal consoles, chat dialogues, and notes cannot execute malicious scripts. |

### 15. Multi-Device Responsive Design System

Hack The AI provides a customized responsive layout engine across four target hardware form-factors:

- **Desktop Workstations (1920×1080 & above):** Side-by-side dual pane view. The left panel houses the 450px task panel with accordion mission tabs; the right pane operates the full multi-window desktop operating system.
- **Laptops (1366×768, 1440×900, 1536×864):** Compact task panel (380px) with adaptive font sizing, scrollable dual-pane burp inspectors, and stacked subtask pills.
- **Tablets (768×1024 / iPad portrait & landscape):** Collapsible mobile sidebar with backdrop drawer, responsive taskbar tab scrollbars, and full-width window focus.
- **Mobile Phones (390×844, 412×915 / iPhone & Android):** Single-pane view with a sticky Mobile View Switcher allowing seamless one-tap switching between '■ Investigation Tasks' and '■ Consensus Desktop', touch targets expanded to min 38–40px, and hardware-accelerated touch scrolling.

## 16. Cloud Deployment & Serverless WSGI Execution

Hack The AI is architected to run seamlessly both in containerized enterprise environments (Docker/Gunicorn/Nginx) and on edge serverless platforms (Vercel Serverless Python):

- **Vercel WSGI Serverless Entry Point:** `api/index.py` imports and exposes the Flask WSGI instance. `vercel.json` routes all global traffic (`/(.*)`) into the Python serverless runtime.
- **Serverless SQLite /tmp Fallback:** Because AWS Lambda/Vercel containers possess read-only filesystems outside of `/tmp`, `config.py` automatically redirects `DATABASE_PATH` to `/tmp/hacktheai.db` when `VERCEL` environment variables are detected.
- **On-Demand Database Seeding:** The application utilizes an atomic `@app.before_request` database initializer that provisions tables, seeds administrative users, and populates the 55+ question catalog on cold starts without manual CLI execution.
- **Stateless Memory-Backed Rate Limiting:** Configured to use `memory://` to prevent timeout delays when external Redis clusters are unprovisioned.

## 17. Complete Codebase Structure & File Directory

HackTheAI-master/ `api/` `index.py` # Vercel Serverless WSGI Entry Point `database/` `hacktheai.db` # Local SQLite relational database instance `.secret_key` # Persistent local secret key storage `routes/` `admin.py` # Lab zip upload, container management, audit logs `api.py` # Mission validation, hints, restart, state endpoints `auth.py` # User login, registration, logout, session init `dashboard.py` # User dashboard, recent activity, XP stats `labs.py` # Lab catalog, detail views, workstation launchers `leaderboard.py` # Dynamic ranking and XP leaderboard `pages.py` # Challenges, achievements, learning tracks, profile `static/` `css/` `core/` # `variables.css`, `reset.css`, `typography.css` `components/` # `components.css`, buttons, badges, modals `layout/` # `layout.css`, sidebar, topbar, responsive grid `pages/` # `ghost_ledger.css`, `ghost_ledger_desktop.css`, # `vanishing_consensus_desktop.css` `js/` `main.js` # Global drawer, toast notifications, CSRF fetch API `ghost_ledger_desktop.js` # Lab 1 Workstation window manager & terminal engine `ghost_ledger_post.js` # Lab 1 Post-investigation cinematic debrief `vanishing_consensus_desktop.js` # Lab 2 Workstation window manager & IoT/AI engine `templates/` `base.html` # Master layout shell with cyber navigation & sidebar `login.html` / `register.html` # Auth views with demo credential guidance `dashboard.html` / `labs.html` # Core portal dashboards and lab catalog `ghost_ledger_workstation.html` # Case NEX-042 full workstation interface `ghost_ledger_post_investigation.html` # Case NEX-042 post-investigation report `vanishing_consensus_workstation.html` # Case NEX-071 full workstation interface `vanishing_consensus_post_investigation.html` # Case NEX-071 post-investigation report `app.py` # Main Flask Application Factory & Middleware `config.py` # Environment Configuration, Secret Key Resolver `extensions.py` # Flask-SQLAlchemy, CSRFProtect, Limiter, Migrate `models.py` # Complete SQLAlchemy ORM Data Models `seed_ghost_ledger.py` # Lab 1 Mission & Quiz Database Seeder `seed_vanishing_consensus.py` # Lab 2 Mission & Quiz Database Seeder `vercel.json` # Vercel Serverless Routing & Build Configuration

## 18. Project Roadmap & Future Scope

| Current Implemented Capabilities (v2.0)                                                                                                                                                                                                                                                                                                                                                                                                                                   | Future Architectural Roadmap (v3.0 Planned)                                                                                                                                                                                                                                                                                                                                                                                                                                                |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <ul style="list-style-type: none"><li>• Full Web3 × AI × IoT Investigation Workstations (Case NEX-042 &amp; NEX-071).</li><li>• In-browser simulated Burp Suite, Terminal, Browser, Attack Graph, Case Files.</li><li>• 55+ Hands-on questions with progressive hints &amp; Capstone quizzes.</li><li>• Responsive Desktop, Laptop, Tablet, and Mobile viewport support.</li><li>• Role-based authentication, CSRF hardening, and serverless Vercel deployment.</li></ul> | <ul style="list-style-type: none"><li>• Live Docker container sandbox execution per student session.</li><li>• Multi-player collaborative SOC incident response rooms with live WebSocket sync.</li><li>• Integration of real EVM testnets (Sepolia/Arbitrum) for live exploit verification.</li><li>• Dynamic AI-generated adversarial scenarios with LLM-driven forensic debriefs.</li><li>• SCORM &amp; LTI integration for university and enterprise LMS certification sync.</li></ul> |

## 19. Conclusion & Final Technical Assessment

**Hack The AI** represents a benchmark implementation of next-generation cybersecurity training infrastructure. By successfully unifying multi-domain technologies—**Decentralized Consensus**, **Autonomous AI Decision Systems**, **Industrial IoT Telemetry**, and **Enterprise RBAC Governance**—into an engaging, story-driven investigation operating system, the platform equips defenders with the exact forensic skills required to detect, analyze, and remediate complex modern threats.

The codebase adheres to clean architectural principles: modular Flask blueprints, decoupled ORM models, robust CSRF and CSP protections, zero-dependency high-performance JavaScript engines, and full cross-device responsive styling. It is production-ready for immediate academic, enterprise, and competitive cybersecurity deployment.

**DESIGNED & DEVELOPED BY LAKSHAY SONI**

Lead System Architect & Cybersecurity Engineer • Hack The AI Platform Project